

GTFOBins: El Arsenal Oculto en tu Sistema



Cómo los binarios legítimos se convierten en la herramienta clave para ataque y defensa.

¿Qué es GTFOBins? No es malware, es creatividad.

GTFOBins es un proyecto que cataloga binarios legítimos de sistemas Unix que pueden ser abusados por un atacante. No se trata de binarios modificados, sino de herramientas que ya existen en el sistema, **usadas de formas inesperadas.**



**Escalar
privilegios**



Saltar restricciones
(sudo, shells
limitadas)



**Leer/escribir
archivos prohibidos**



**Lanzar shells o
reverse shells**

<https://gtfobins.github.io/>

La anatomía de una entrada en GTFOBins

Cada entrada es una “chuleta” que te dice exactamente qué puedes hacer con un binario si tienes ciertos permisos. La información está organizada en funciones claras y directas.

/bin/tar A short for sinenu binario uses orecon function win axhalled nanoded fil'Obins web page.	Shell Cómo conseguir una shell interactiva.
Sudo sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh	Sudo Cómo abusar del binario si puedes ejecutarlo con `sudo`.
SUID ...	SUID Cómo explotarlo si tiene el bit SUID activado.
Shell shell tar -cf /dev/null	
File write LFILE=file_to_write; tar -cf \$LFILE /dev/null	File write Técnicas para escribir archivos.
File read LFILE=file_to_read; tar -cf \$LFILE /dev/null	File read Técnicas para leer archivos.
Capabilities ...	Capabilities, Limited shells, etc.
Limited shells ...	

PERSPECTIVA **RED TEAM**: Explotando lo que ya existe

Para el atacante, GTF0Bins es la navaja suiza que le permite moverse sin ser detectado.



El camino rápido hacia '**root**': CTFs y Escalada de Privilegios

En un CTF, es la diferencia entre quedarse bloqueado y conseguir la flag. En un entorno real, es el primer paso para tomar control total del sistema.

Paso 1: Enumerar Permisos

Se ejecutan comandos para encontrar binarios con permisos especiales:

```
# Buscar binarios SUID  
find / -perm -4000 -type f 2>/dev/null
```

```
# Comprobar qué se puede ejecutar con sudo  
sudo -l
```



Paso 2: Consultar y Ejecutar

Se busca el binario encontrado en GTFOBins. Se aplica la 'receta' documentada para, por ejemplo, usar `tar` o `vim` para leer `/etc/shadow` o generar una shell como root.

La Táctica del Fantasma: "Living off the Land"

En un pentesting real, el objetivo es la discreción. GTFOBins es la herramienta perfecta para la técnica "Living off the Land" (LOTL): usar solo lo que ya existe en el sistema.

Reduce la huella



No se introducen herramientas externas que puedan ser detectadas por un antivirus o EDR.

Evade defensas



El uso de binarios legítimos es más difícil de distinguir de la actividad normal del administrador.

Supera entornos restringidos



Esencial en contenedores, `chroots` o cuando `sudo` solo permite ejecutar comandos específicos.



**Pero toda arma
tiene dos filos...**

PERSPECTIVA **BLUE TEAM**: Fortaleciendo las Defensas

Para el defensor, GTF0Bins es el manual que revela las debilidades ocultas del sistema.



Usando el conocimiento del atacante para construir un escudo

GTFOBins no es solo para atacar. Es una herramienta de auditoría y detección indispensable para cualquier equipo de defensa.

1. Auditar Configuraciones

'Te abre los ojos sobre cuántos binarios aparentemente inocentes pueden ser peligrosos si se configuran mal.'

Permite revisar proactivamente los permisos ``sudo`` y los binarios ``SUID`` que no deberían estar en producción.



2. Crear Reglas de Detección

'Te da ideas para crear reglas de detección sobre usos anómalos de ciertos comandos.'

Ejemplo: Monitorizar si ``tar`` o ``less`` generan procesos hijos como ``sh`` o ``bash``, especialmente si son ejecutados por usuarios no privilegiados.



Un Proyecto, Dos Perspectivas, Un Mismo Valor

GTFOBins es un proyecto simple en concepto, pero de un impacto inmenso. Su valor es universal para cualquier profesional de la ciberseguridad.

RED TEAM

Catálogo de Abuso



- **Para CTF:** Acelera drásticamente la escalada de privilegios.
- **Para Pentesting:** Proporciona un arsenal de técnicas de 'Living off the Land' para operar con sigilo.

BLUE TEAM

Manual de Defensa



- **Para SOC/Defensa:** Enseña por dónde pueden producirse movimientos laterales y elevaciones de privilegios silenciosas.
- **Para Hardening:** Es una guía esencial para auditar y corregir configuraciones de permisos peligrosas.